

Vulnerability Assessment Report

Date:17/06/2026

CONTENTS

1. Target.....	3
2. Executive Summary.....	4
3. Methodology.....	5
4. Network Reconnaissance.....	6
5. HTTP Security Header Analysis.....	7
6. Vulnerability Findings.....	9
7. Detailed Attack Surface Map.....	21
8. OWASP ZAP Scan Summary.....	23
9. Browse DevTools Key Observation.....	24
10. Remediation Recommendation.....	25
11. Tools & Command Reference.....	27
12. Conclusion.....	28

Field	Details
Target URL	http://testphp.vulnweb.com
IP Address	44.228.249.3
Hosting Provider	Amazon Web Services (AWS) — us-west-2
Server Technology	nginx 1.19.0, PHP 5.6.40-38, MySQL
Assessment Date	June 17, 2026
Classification	Confidential
Report Version	1.0

1. Executive Summary

A comprehensive vulnerability assessment was conducted against testphp.vulnweb.com using Nmap, OWASP ZAP and browser Devtools. The application intentionally designed with security flaws for educational purposes, having many critical, high and medium risk vulnerabilities.

RISK OVERVIEW

Severity	Count	Risk Level
Critical	4	Immediate exploitation possible
High	5	Significant impact
Medium	6	Moderate risk
Low	5	Informational / Minor
Informational	4	Observations only

2. Methodology

Phase	Tool/Technique	Purpose
1. Reconnaissance	Nmap (-sV -A -p-)	Port scanning, service & version detection, OS fingerprinting
2. Passive Scanning	OWASP ZAP (Spider mode) & Browser DevTools	URL discovery, hidden endpoints, form identification
3. Header Analysis	OWASP ZAP passive scan & curl -I / Browser DevTools Network tab	Security header audit (CSP, HSTS, X-Frame-Options, etc.)
4. Configuration Analysis	Browser DevTools & OWASP ZAP active scan	Directory listing, sensitive file exposure, tech stack disclosure
5. Active Scanning	OWASP ZAP (Active Scan mode)	SQL injection, XSS, LFI, parameter tampering detection

3. Network Reconnaissance(Nmap)

Nmap Command

```
nmap -sV -A -p- -T4 testphp.vulnweb.com
```

Scan Results

Nmap scan report for testphp.vulnweb.com (44.228.249.3)

Host is up (0.047s latency).

rDNS record: ec2-44-228-249-3.us-west-2.compute.amazonaws.com

PORT	STATE	SERVICE	VERSION
80/tcp	open	http	nginx 1.19.0
443/tcp	filtered	https	-
999/tcp	filtered	-	-

Key Findings

- Only one open port (80) serves HTTP
- Port 443 (HTTPS) is filtered — no TLS encryption available
- Web server: nginx 1.19.0 (released 2020, multiple CVEs since)
- Backend language: PHP 5.6.40-38 (End-of-Life since December 2018 — 9.8 Critical)

4. HTTP Security Header Analysis

Raw Headers(using curl -I and ZAP)

HTTP/1.1 200 OK

Server: nginx/1.19.0

Date: [redacted]

Content-Type: text/html

Connection: close

X-Powered-By: PHP/5.6.40-38

Content-Length: [redacted]

Security Header Audit

Header	Status	Risk	Recommendation
Strict-Transport-Security	Missing	High	Implement HSTS (site is HTTP-only, critical flaw)
X-Frame-Options	Missing	Medium	Add DENY or SAMEORIGIN
X-Content-Type-Options	Missing	Medium	Add nosniff
Content-Security-Policy	Missing	Medium	Define CSP directives
X-XSS-Protection	Missing	Low	Add 1; mode=block
Referrer-Policy	Missing	Low	Add strict-origin-when-cross-origin
Permissions-Policy	Missing	Low	Restrict feature permissions
Server header	Exposed: nginx/1.19.0	Low	Obfuscate or remove
X-Powered-By	Exposed: PHP/5.6.40-38	High	Remove — reveals EOL PHP version

5. Vulnerability Findings

VULN-001:SQL Injection - Multiple Endpoints

Field	Details
Severity	Critical (CVSS 9.8)
Category	SQL Injection (CWE-89)
Endpoints	listproducts.php?cat=, artists.php?artist=, product.php?pic=, userinfo.php?uname=, AJAX/infocateg.php?id=, Mod_Rewrite_Shop/details.php?id=
Description	User-supplied parameters are directly concatenated into SQL queries without sanitization or parameterization. Attackers can extract the entire database, including user credentials, credit card data, and application source code.
Evidence	GET /listproducts.php?cat=1+UNION+SELECT+ALL+1,table_name,3,4,5,6,7,8,9,10,11+FROM+information_schema.tables returns database schema.
Remediation	Use prepared statements (PDO parameterized queries). Apply strict input validation with whitelist filtering.

VULN-002: XSS

Field	Details
Severity	Critical (CVSS 7.3)
Category	Cross-Site Scripting (CWE-79)
Endpoints	search.php (POST searchFor), listproducts.php?cat=, guestbook.php, secured/newuser.php (Blind XSS via uphone)
Description	Multiple instances of reflected and stored XSS. The listproducts.php?cat parameter accepts <script> tags and event handlers. The guestbook stores unsanitized user input.
Evidence	GET /listproducts.php?cat= <IMG+sRC=X+onerror=alert(1)> executes JavaScript.
Remediation	Implement output encoding (HTML entity encoding). Use Content-Security-Policy headers. Validate and sanitize all user input server-side.

VULN-003: Local File Inclusion

Field	Details
Severity	Critical (CVSS 8.6)
Category	Path Traversal (CWE-22) / LFI
Endpoint	showimage.php?file=
Description	The file parameter does not validate or sanitize input paths. Attackers can read arbitrary files from the server filesystem, including /etc/passwd, application source code, and configuration files containing database credentials.
Evidence	showimage.php?file=../../etc/passwd returns system files. The parameter also accepts URLs: showimage.php?file=http://127.0.0.1:22 (SSRF potential).
Remediation	Whitelist allowed filenames. Use basename() and realpath() to restrict to intended directory. Disable remote file inclusion (allow_url_fopen).

VULN-004: PHP End-of-Life Version

Field	Details
Severity	Critical (CVSS 9.8)
Category	Outdated Software (CWE-1104)
Evidence	X-Powered-By: PHP/5.6.40-38 confirmed via phpinfo.php
Description	PHP 5.6 has been end-of-life since December 31, 2018. No security patches are released. Multiple critical CVEs affect this version including remote code execution vulnerabilities.
Remediation	Upgrade to PHP 8.x immediately. Test application compatibility before deployment.

VULN-005: Weak Authentiction Mechanism

Field	Details
Severity	High (CVSS 7.4)
Category	Broken Authentication (CWE-287)
Endpoint	/admin/, /userinfo.php
Description	Login forms accept weak/default credentials. No account lockout mechanism exists. Session tokens are predictable and not regenerated on authentication.
Evidence	Default credentials discovered: Host: 127.0.0.1, Username: acuart, Password: trustno1
Remediation	Implement strong password policies, account lockout, multi-factor authentication, and secure session management.

VULN-006: Sensitive Information Disclosure

Field	Details
Severity	High (CVSS 7.5)
Category	Information Exposure (CWE-200)
Endpoint	/pictures/credentials.txt
Description	A plaintext credentials file is publicly accessible, exposing usernames and passwords for the application database.
Remediation	Remove all credential files from public webroot. Store credentials in environment variables or secure vaults.

VULN-007: Source Code Disclosure

Field	Details
Severity	High (CVSS 7.5)
Category	Exposure of Backup File (CWE-530)
Endpoints	/index.zip, /index.bak, /.idea/workspace.xml
Description	Full application source code available for download via backup archives. IDE project files reveal internal paths and configuration. The .idea/workspace.xml exposes development environment structure.
Remediation	Remove all backup/IDE files from production. Use .htaccess or nginx deny rules.

VULN-008: Directory Listing Enabled

Field	Details
Severity	High (CVSS 5.3)
Category	Directory Listing (CWE-548)
Endpoints	/admin/, /.idea/, /.idea/scopes/, /CVS/
Description	Directory listing is enabled on multiple paths, allowing attackers to browse file structures and discover sensitive resources. /CVS/Root exposes version control metadata.
Remediation	Disable directory listing in nginx: autoindex off;.

VULN-009: Database Schema Exposure

Field	Details
Severity	High (CVSS 6.5)
Category	Sensitive Data Exposure (CWE-200)
Endpoint	/admin/create.sql
Description	The full database creation script is publicly accessible, revealing table structures, column names, data types, constraints, and relationships.
Remediation	Restrict access to SQL files. Store database schemas outside webroot.

VULN-010: No HTTPS/TLS Encryption

Field	Details
Severity	Medium (CVSS 5.9)
Category	Cleartext Transmission (CWE-319)
Description	All traffic flows over unencrypted HTTP (port 443 filtered). All data — including credentials, session cookies, and user input — is transmitted in plaintext and susceptible to interception (Man-in-the-Middle).
Remediation	Obtain and configure TLS certificate. Redirect all HTTP traffic to HTTPS. Implement HSTS.

VULN-011: Missing ANti-Clickjacking Header

Field	Details
Severity	Medium (CVSS 5.3)
Category	Clickjacking (CWE-1021)
Evidence	X-Frame-Options header absent
Description	The application can be embedded in an <iframe> on an attacker's site, enabling clickjacking attacks where users unknowingly perform actions.
Remediation	Add X-Frame-Options: DENY or Content-Security-Policy: frame-ancestors 'none'.

VULN-012: No CSP

Field	Details
Severity	Medium (CVSS 5.3)
Category	CSP Not Set (CWE-693)
Description	No CSP header is set, allowing all inline scripts and styles to execute. This exacerbates XSS vulnerabilities as there is no restriction on script sources.
Remediation	Implement a strict Content-Security-Policy header.

VULN-013: Cross-Site Request Forgery

Field	Details
Severity	Medium (CVSS 5.0)
Category	CSRF (CWE-352)
Endpoints	Login form, new user registration (/secured/newuser.php), guestbook
Description	No CSRF tokens are implemented on any forms. An attacker can forge requests to change user data or perform actions on behalf of an authenticated user.
Remediation	Implement anti-CSRF tokens on all state-changing forms. Use SameSite cookie attribute.

VULN-014: Insecure crossdomain.xml

Field	Details
Severity	Medium (CVSS 4.3)
Category	Cross-Domain Policy (CWE-942)
Endpoint	/crossdomain.xml
Description	The Flash cross-domain policy file is publicly accessible and may be misconfigured to allow unrestricted cross-domain requests from Flash-based applications.
Remediation	Remove crossdomain.xml if not needed. Restrict to specific trusted domains.

VULN-015: Email Address Disclosure

Field	Details
Severity	Medium (CVSS 4.0)
Category	Information Disclosure (CWE-200)
Evidence	Emails discovered: wvs@acunetix.com, test@gmail.com, wasp@acunetix.com
Description	Multiple email addresses are exposed in page source and application responses, providing vectors for social engineering and phishing.
Remediation	Obfuscate or remove email addresses from public-facing pages.

LOW FINDINGS

VULN-016: Server Version Leak

- Server: nginx/1.19.0 header disclosed
- Fix: Set server_tokens off; in nginx config

VULN-017: PHP Version Leak

- X-Powered-By: PHP/5.6.40-38 header disclosed
- Fix: Set expose_php = Off in php.ini

VULN-018: Missing X-Content-Type-Options

- MIME-sniffing possible, leading to drive-by download attacks
- Fix: Add X-Content-Type-Options: nosniff

VULN-019:Charset Mismatch

- Headers declare one charset; meta tags declare another
- Fix: Ensure charset consistency across headers and HTML

VULN-020: Generic Email Address Disclosure

- Low-risk exposure of test emails that may aid reconnaissance

INFORMATIONAL

INFO-001: CVS Metadata Exposure

- Exposes internal version control root path

INFO-002: .htaccess File Exposure

- Mod_Rewrite_Shop/.htaccess accessible — reveals rewrite rules

INFO-003: MySQL Server Scripts Exposed

- /_mmServerScripts/mysql.php accessible, potentially exposing DB functions

INFO-004: phpinfo.php Exposure

- /secured/phpinfo.php accessible — exposes full PHP configuration, environment variables, and server paths

6. Detailed Attack Surface Map

testphp.vulnweb.com (44.228.249.3:80)

— /	[Home page]
— /search.php	[POST - Reflected XSS, SQLi]
— /listproducts.php?cat=	[GET - SQLi, XSS]
— /artists.php?artist=	[GET - SQLi]
— /product.php?pic=	[GET - SQLi]
— /userinfo.php?uname=	[POST - Blind SQLi]
— /showimage.php?file=	[GET - LFI, SSRF]
— /guestbook.php	[POST - Stored XSS]
— /secured/phpinfo.php	[phpinfo disclosure]
— /secured/newuser.php	[POST - Blind XSS, CSRF]
— /admin/	[Directory listing, login page]
— /admin/create.sql	[DB schema exposure]
— /pictures/credentials.txt	[Plaintext credentials]
— /index.zip	[Full source code backup]
— /index.bak	[Backup file]
— /.idea/workspace.xml	[IDE project file]
— /CVS/Root	[CVS metadata]
— /crossdomain.xml	[Flash cross-domain policy]
— /Mod_Rewrite_Shop/	[Alternate shop interface]
— /details.php?id=	[SQLi]
— /AJAX/infocateg.php?id=	[SQLi]
— /_mmServerScripts/mysql.php	[MySQL admin scripts]

└── /robots.txt

[Crawl rules]

7. OWASP ZAP Scan Summary

Based on Document ZAP scans of this target:

Alert Name	Risk Level	Instances
Content Security Policy (CSP) Header Not Set	Medium	1
Missing Anti-clickjacking Header	Medium	1
Server Leaks Version Info via X-Powered-By	Low	1
Server Leaks Version Info via Server Header	Low	2
X-Content-Type-Options Header Missing	Low	2
Charset Mismatch (Header vs Meta)	Informational	1
SQL Injection (Active Scan)	High	Multiple
Reflected XSS (Active Scan)	High	Multiple
Directory Listing	Medium	3

8. Browser DevTools Key Observation

When analyzing the site via Browser DevTools(F12-> Network Tab)

1. Response Headers Tab: Confirm missing security headers listed in Section 4.2
2. Sources Tab: View exposed PHP source code comments containing email addresses and internal paths
3. Console Tab: No CSP violations (because CSP isn't set), but XSS payloads execute freely
4. Application Tab → Cookies: Session cookies lack Secure, HttpOnly, and SameSite flags
5. Elements Tab: Inspect forms — note absence of CSRF tokens in hidden input fields

9. Remediation Recommendations

Immediate(Critical/High/Priority)

#	Action	Priority
1	Upgrade PHP to latest supported version (8.x)	Critical
2	Implement prepared statements (PDO) across all SQL queries	Critical
3	Add input validation & output encoding for all user-supplied data	Critical
4	Remove/restrict all sensitive files (index.zip, credentials.txt, create.sql, phpinfo.php)	Critical
5	Enable HTTPS with valid TLS certificate + redirect HTTP → HTTPS	High
6	Disable directory listing on all paths	High
7	Add CSRF tokens to all state-changing forms	High

Short-Term(Medium Priority)

#	Action	Priority
8	Implement Content-Security-Policy header	Medium
9	Add X-Frame-Options: DENY	Medium
10	Add X-Content-Type-Options: nosniff	Medium
11	Hide server version: server_tokens off; + expose_php = Off	Medium
12	Implement SameSite=Strict attribute on session cookies	Medium

Long-Term(Low Priority)

#	Action	Priority
13	Add Referrer-Policy, Permissions-Policy, HSTS headers	Low
14	Conduct regular automated scanning and manual pentests	Low
15	Implement proper error handling (no stack traces to users)	Low

10. Tools & Command Reference

Nmap Reconnaissance

```
nmap -sV -A -p- -T4 testphp.vulnweb.com
```

```
nmap -F testphp.vulnweb.com
```

```
nmap --script vuln testphp.vulnweb.com
```

```
nmap -sV --script=banner testphp.vulnweb.com
```

OWASP ZAP (Manual/CLI)

```
zap-cli quick-scan --self-contained --spider --ajax-spider -o -l Pass  
http://testphp.vulnweb.com/
```

```
zap-cli report -o zap_report.html -f html
```

Browser DevTools (Manual Steps)

1. F12 → Network Tab → Reload page → Inspect response headers
2. F12 → Application Tab → Cookies → Check Secure/HttpOnly/SameSite flags
3. F12 → Sources Tab → Browse for exposed comments/config files
4. F12 → Console → Test XSS: document.cookie in the console after navigating to vulnerable page

Curl for Header Inspection

```
curl -I http://testphp.vulnweb.com/
```

```
curl -I http://testphp.vulnweb.com/secured/phpinfo.php
```

CONCLUSION

testphp.vulnweb.com is a deliberately vulnerable test application designed by Acunetix for security training. The assessment confirmed:

- 4 Critical vulnerabilities including SQL injection (database compromise), XSS (client-side attacks), LFI (server file disclosure), and an EOL PHP version (9.8 CVSS)
- 5 High vulnerabilities including credential exposure, source code leaks, directory listing, and weak authentication
- 6 Medium vulnerabilities including missing HTTPS, missing security headers, and CSRF
- 5 Low vulnerabilities primarily server version disclosure and MIME-sniffing issues

The exploitation chain is straightforward: an attacker could use SQL injection at `/listproducts.php?cat=` to extract user credentials, leverage LFI at `/showimage.php?file=` to read configuration files containing database access and pivot to full server compromise through the outdated PHP version.